

Injecting Security into Build Pipelines #DevSecOps

In this article, we will discuss how to integrate security into our day-to-day lives with as little overhead as possible. DevSecOps is enabling teams to deploy applications securely to production environments multiple times in a day. Let's see how this is done.

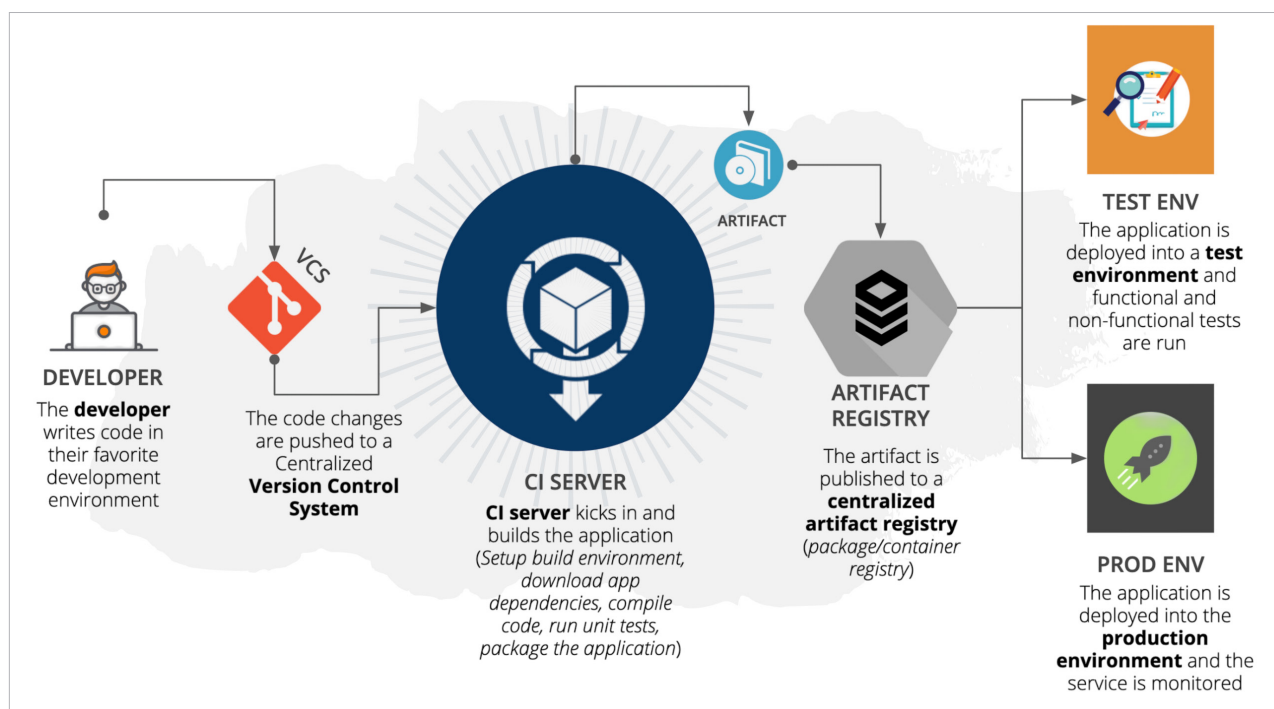


Figure 1: Path to production



In a real CI tool (Jenkins Blue Ocean), the process or the development jobs look like what's shown in Figure 1.

Developers have been automating as much as possible to meet the practice of continuous deployment. At first glance, this probably looks like the perfect setup for delivering certain software. What do you think? Please refer to Figure 2.

How about what's shown in Figure 3?

Disclaimer: You might notice that I am referring to a lot of tools throughout this article. I have chosen all these tools based on my experience. So, I strongly recommend that you analyse before choosing any tool because like you and me, every application is different and special.

Build pipelines are the sweet spot for integrating security tools



Figure 2: Sample build pipeline

so that all the security practices are verified, regardless of which tools each developer has in his/her development environment.

Now let's think about the list of practices we want to automate. The composition of application code, typically, is:

- Application code
- Application dependencies
- Application runtime
- Infrastructure code